Health Data Protection and AI Governance Agreement

Effective Date: 1 January 2026
Parties: The Data Controller ("the Company") and its end users ("Data Subjects").

This Agreement sets out the binding obligations of the Company with respect to the collection, processing, storage, and automated analysis of personal and health-related data. Failure to comply with any clause below may expose the Company to regulatory penalties, civil liability, and termination of its operating licence.

1. Lawful Basis and Consent

1.1 The Company shall not collect or process any personal data unless it has first obtained the explicit, freely given, and informed consent of the Data Subject for each distinct purpose of processing.

1.2 Where data is classified as health data, the Company must obtain a separate, affirmative opt-in consent that is recorded and time-stamped at the moment it is given.

1.3 Consent must be as easy to withdraw as it is to give, and withdrawal must take effect within seventy-two (72) hours of the request.

2. Data Minimisation and Purpose Limitation

2.1 The Company shall collect only the personal data that is strictly necessary for the stated purpose, and shall not repurpose data for any use not disclosed at the time of collection.

2.2 Personal data shall be retained for no longer than is necessary to fulfil its purpose. In no event shall health data be retained for more than twenty-four (24) months after the Data Subject's account becomes inactive.

3. Security of Processing

3.1 All personal data must be encrypted in transit using TLS 1.2 or higher, and encrypted at rest using AES-256 or an equivalent industry-standard algorithm.

3.2 The Company shall enforce role-based access control and multi-factor authentication for all employees and contractors who can access personal data.

3.3 The Company shall commission an independent third-party penetration test and security audit at least once every twelve (12) months.

4. Data Residency and Cross-Border Transfers

4.1 Personal data belonging to residents of the European Economic Area must be stored and processed exclusively within the European Economic Area, unless an approved transfer mechanism is in place.

4.2 The Company shall not transfer personal data to any third country that has not been recognised as providing an adequate level of data protection.

5. Automated Decision-Making and AI Governance

5.1 Where the Company uses automated or AI-driven systems to make decisions that materially affect a Data Subject, it must provide a clear explanation of the logic involved and offer a route to human review.

5.2 The Company shall maintain a written record of every AI model used in production, including its purpose, training data sources, and a documented bias assessment.

5.3 No automated system shall make a final decision concerning a Data Subject's medical treatment without the review and approval of a qualified human clinician.

6. Sub-Processors and Third Parties

6.1 The Company shall not engage any sub-processor to handle personal data unless that sub-processor is bound by contractual obligations no less protective than those in this Agreement.

6.2 The Company shall maintain and publish a current list of all sub-processors that have access to personal data.

7. Breach Notification

7.1 In the event of a personal data breach, the Company shall notify the relevant supervisory authority without undue delay and in any case within seventy-two (72) hours of becoming aware of the breach.

7.2 Where a breach is likely to result in a high risk to the rights of Data Subjects, the Company shall also notify the affected Data Subjects without undue delay.

8. Data Subject Rights

8.1 The Company shall enable Data Subjects to access, rectify, and export their personal data, and shall fulfil any such request within thirty (30) days.

8.2 The Company shall delete a Data Subject's personal data within thirty (30) days of a valid erasure request, except where retention is required by law.

9. Accountability and Governance

9.1 Where the Company processes the health data of more than ten thousand (10,000) Data Subjects, it shall appoint a Data Protection Officer responsible for compliance with this Agreement.

9.2 The Company shall maintain a written record of all processing activities and make it available to the supervisory authority on request.